

Esercizio S3L5 - Creazione pratica di una regola Firewall

Prima di procedere con il filtraggio del traffico, è stato necessario configurare il posizionamento strategico di pfSense come punto di sbarramento (Gateway) tra le due macchine virtuali. Per fare in modo che il traffico passi obbligatoriamente attraverso il firewall, le due macchine **non** devono trovarsi sulla stessa sottorete fisica/virtuale.

Fase 1: Configurazione dell'Ambiente di Virtualizzazione (Hypervisor)

Dentro VirtualBox sono state create reti interne separate (*Internal Network* o *LAN Subnets*) per garantire l'isolamento dei domini di broadcast:

- **pfSense:** Configurato con 3 schede di rete:
 1. **WAN:** Connessa in NAT/Bridged (per eventuale accesso a Internet).
 2. **LAN (Segmento Kali):** Connessa alla rete interna denominata kalinet.
 3. **OPT1 (Segmento Meta):** Connessa alla rete interna denominata metanet.
- **Kali Linux:** Configurato con una sola scheda di rete connessa alla rete interna kalinet.
- **Metasploitable 2:** Configurato con una sola scheda di rete connessa alla rete interna metanet.

Fase 2: Assegnazione delle Interfacce dalla Console di pfSense

All'avvio di pfSense, tramite terminale, si è proceduto all'assegnazione delle schede di rete fisiche alle interfacce di sistema:

Sono state associate le interfacce rilevate dal sistema le1, le2 e vitnet0:

- WAN è stata associata a le1 (interfaccia verso l'esterno).
- LAN è stata associata a le2 (interfaccia verso Kali).
- OPT1 è stata associata a vitnet0 (interfaccia verso Metasploitable2).

Fase 3: Configurazione degli Indirizzi IP (Network Addressing)

Sempre dalla console di pfSense, sono stati assegnati gli indirizzi IP statici che fungeranno da Gateway per i rispettivi segmenti di rete:

1. Interfaccia WAN

- **Tipo di configurazione:** DHCP (IPv4).
- **Subnet Mask:** /24 (255.255.255.0).

2. Interfaccia LAN (Rete Kalinet)

- **Tipo di configurazione:** Statica (IPv4).
- **Indirizzo IP:** 192.168.10.11
- **Subnet Mask:** /24 (255.255.255.0).
- **DHCP:** abilitato (range 192.168.10.100 - 192.168.10.200)

3. Interfaccia OPT1 (Rete Metasploitable)

- **Tipo di configurazione:** Statica (IPv4).
- **Indirizzo IP:** 192.168.30.1/24
- **Subnet Mask:** /24 (255.255.255.0).
- **DHCP:** abilitato (range 192.168.30.100 - 192.168.30.200)

Le macchine sono connesse tramite Internal Network e non con modalita' Bridged o NAT per i seguenti motivi di sicurezza:

- Isolamento dalla rete fisica: Metasploitable2 e' una macchina volutamente vulnerabile; esporla sulla rete di casa sarebbe pericoloso.
- Simulazione realistica: pfSense funge da router/firewall tra le due reti, esattamente come avviene in un ambiente aziendale reale.
- Controllo del traffico: tutto il traffico tra Kali e Metasploitable2 passa attraverso pfSense, permettendo di applicare regole firewall.

Fase 4: Configurazione Kali Linux

Kali Linux ha ricevuto la configurazione di rete tramite DHCP da pfSense. Successivamente e' stata resa permanente nel file /etc/network/interfaces:

```
auto eth0
iface eth0 inet static
    address 192.168.10.10
    netmask 255.255.255.0
    gateway 192.168.10.11
    dns-nameservers 8.8.8.8 8.8.4.4
```

Verifica della connettivita':

- ping 192.168.10.11 → OK (pfSense LAN raggiungibile)

- ping 8.8.8.8 → OK (Internet tramite pfSense)
- ping google.com → OK (DNS funzionante)
- ping 192.168.30.101 → OK (Metasploitable2 raggiungibile)

Fase 5: Configurazione Metasploitable2

Metasploitable2 ha ottenuto automaticamente un indirizzo IP dal server DHCP di pfSense sull'interfaccia OPT1.

L'indirizzo IP assegnato e' stato: 192.168.30.101/24, con gateway 192.168.30.1 (pfSense OPT1).

Fase 6: Configurazione Regole Firewall

Una volta accertata la piena comunicazione tra le macchine, si è proceduto all'applicazione della regola di sicurezza sul firewall pfSense per inibire l'accesso a Kali Linux.

Regola “Blocca accesso DVWA”

Per bloccare l'accesso alla DVWA da Kali Linux, e' stata aggiunta una nuova regola SOPRA quella di Allow, in modo che venga processata per prima da pfSense.

Accesso alla dashboard web di pfSense **Firewall > Rules > LAN**.

Creazione di una regola restrittiva posizionata **in cima alla lista**.

Configurazione dei parametri della regola:

- **Action:** Block (i pacchetti vengono scartati silenziosamente senza generare risposta per l'attaccante).
- **Interface:** LAN
- **Protocol:** Any (per bloccare sia il traffico web TCP, sia le scansioni UDP/ICMP).
- **Source:** Indirizzo IP di Kali Linux.
- **Destination:** Indirizzo IP di Metasploitable (192.168.30.101).

L'ordine finale delle regole sulla interfaccia LAN e' il seguente:

1. BLOCK - Kali → Metasploitable2:80 (blocca DVWA)
2. PASS - LAN net → any (permette tutto il resto)

Questo ordine garantisce che il blocco specifico sulla porta 80 verso Metasploitable2 venga applicato prima della regola permissiva generale. Il traffico su altre porte (es. ping ICMP, SSH, ecc.) continua a funzionare normalmente grazie alla regola Pass sottostante.

Fase 8: Verifica e Test

I seguenti test sono stati eseguiti da Kali Linux per verificare il corretto funzionamento della configurazione:

Test	Comando	Risultato
Raggiungibilità pfSense	ping 192.168.10.11	OK
Accesso Internet	ping 8.8.8.8	OK
Risoluzione DNS	ping google.com	OK
Raggiungibilità Metasploitable2	ping 192.168.30.101	OK
Accesso DVWA (porta 80)	curl http://192.168.30.101	BLOCCATO

L'esercizio ha permesso di configurare con successo un ambiente di sicurezza informatica isolato e funzionale, raggiungendo tutti gli obiettivi prefissati:

- Isolamento delle reti: Kali Linux e Metasploitable2 si trovano su reti separate (192.168.10.0/24 e 192.168.30.0/24), gestite da pfSense come router e firewall.
- Connettività controllata: Kali Linux può comunicare con Metasploitable2 attraverso pfSense, ma solo secondo le regole firewall definite.
- Blocco selettivo: la regola firewall implementata blocca specificamente l'accesso HTTP (porta 80) a Metasploitable2 da Kali, impedendo l'accesso alla DVWA e qualsiasi tentativo di scan web, mantenendo però attiva la connettività su altri protocolli.
- Sicurezza dell'host: l'uso di Internal Network in VirtualBox garantisce che Metasploitable2, essendo una macchina volutamente vulnerabile, non sia mai esposta sulla rete fisica reale.

Immagini a seguire :

```

Bootup complete

FreeBSD/amd64 (pfSense.localdomain) (ttyv0)

VirtualBox Virtual Machine - Netgate Device ID: 67ac9f55ba82e1a13c1d

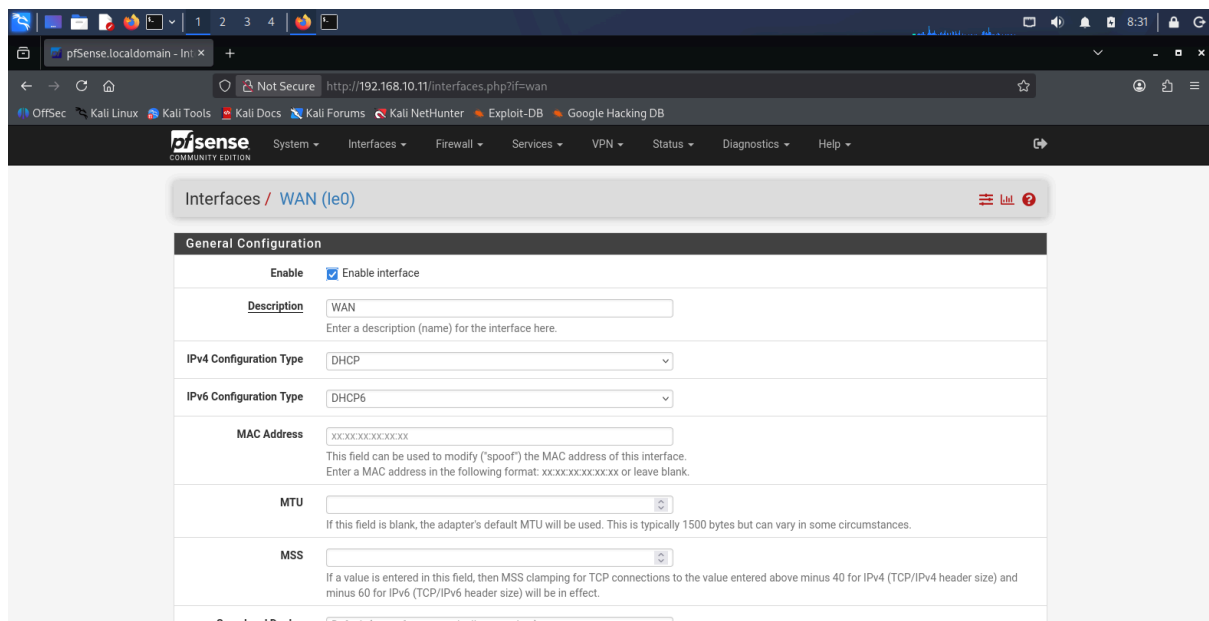
*** Welcome to pfSense 2.7.2-RELEASE (amd64) on pfSense ***

WAN (wan)      -> le0      -> v4/DHCP4: 10.0.2.15/24
                                   v6/DHCP6: fd17:625c:f037:2:a00:27ff:fe12:de2e/
64
LAN (lan)      -> le1      -> v4: 192.168.10.11/24
OPT1 (opt1)    -> vtnet0    -> v4: 192.168.30.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults  13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                 15) Restore recent configuration
7) Ping host                   16) Restart PHP-FPM
8) Shell

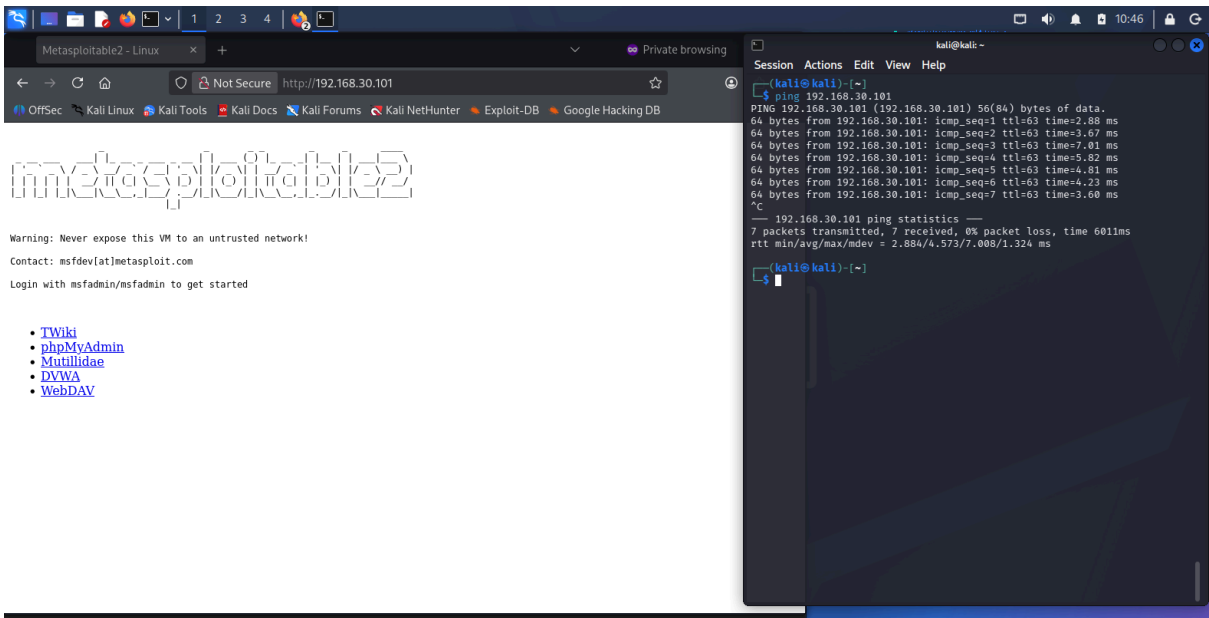
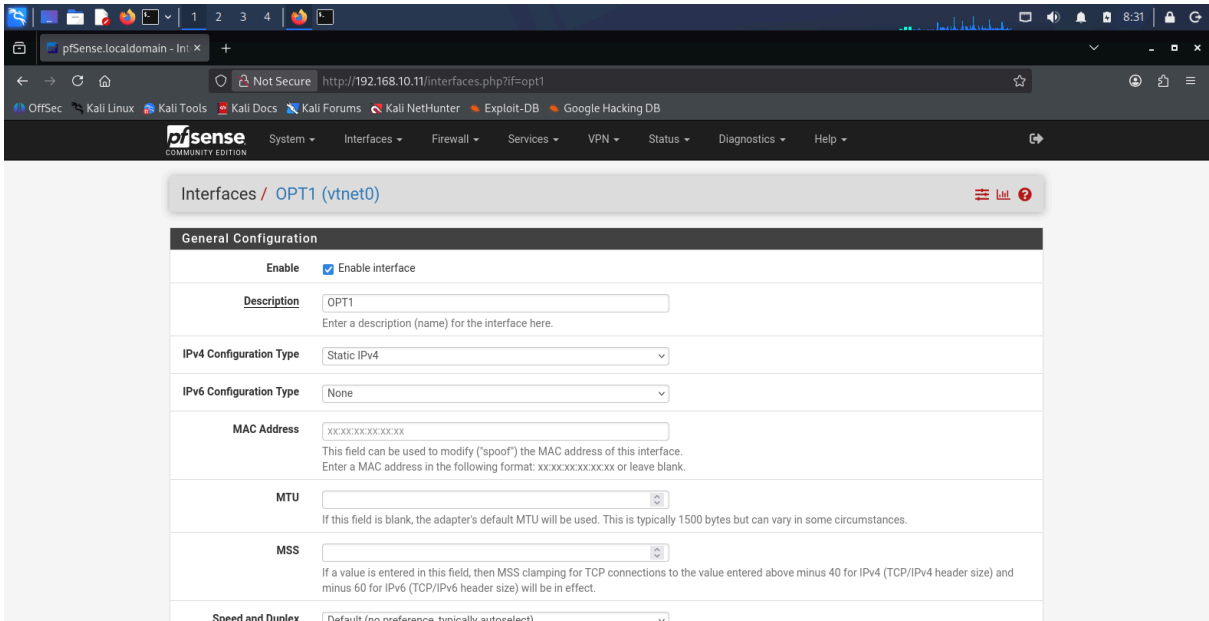
Enter an option: █

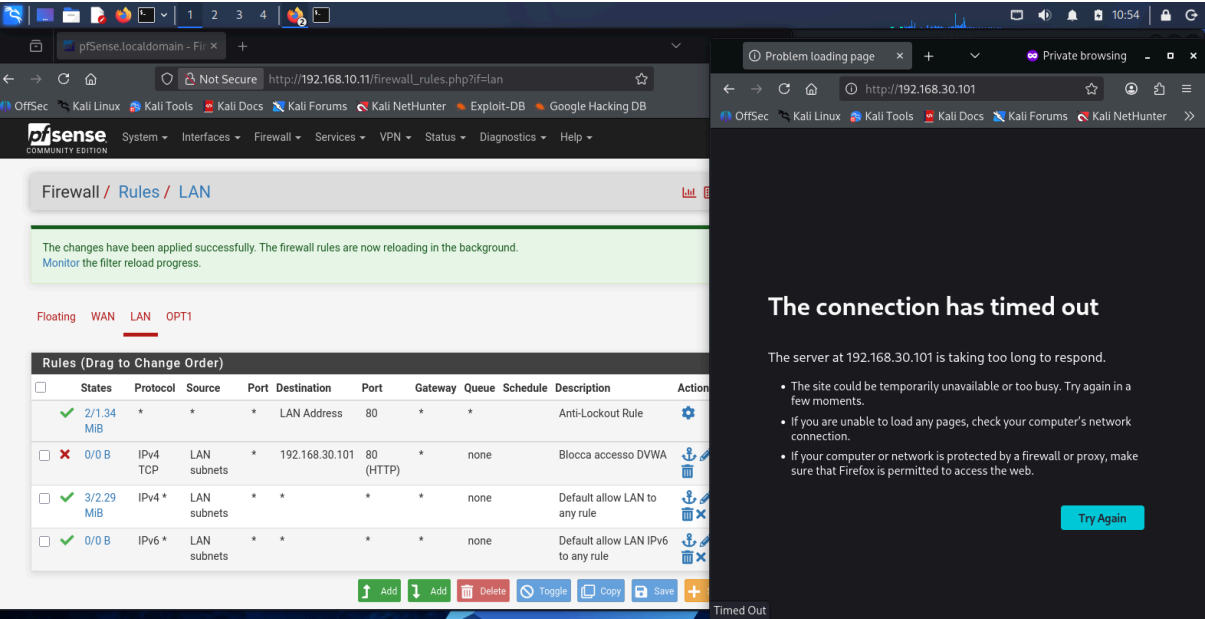
```



The screenshot shows the pfSense web interface in a browser. The address bar shows the URL `http://192.168.10.11/interfaces.php?if=wan`. The page title is "Interfaces / WAN (le0)". The "General Configuration" section is expanded, showing the following settings:

- Enable:** ☒ Enable interface
- Description:** WAN (with a text input field containing "WAN")
- IPv4 Configuration Type:** DHCP
- IPv6 Configuration Type:** DHCP6
- MAC Address:** xxxxxxxxxxxx (with a text input field containing "xxxxxxxxxxxx")
- MTU:** (with a dropdown menu)
- MSS:** (with a dropdown menu)
- Speed and Duplex:** Default (no reference, manually settable)





pfSense.localdomain - Firefox

Not Secure http://192.168.10.11/firewall_rules.php?if=lan

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

pfSense COMMUNITY EDITION

System Interfaces Firewall Services VPN Status Diagnostics Help

Firewall / Rules / LAN

The changes have been applied successfully. The firewall rules are now reloading in the background. Monitor the filter reload progress.

Floating WAN LAN OPT1

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓ 2/1.34 MIB	*	*	*	LAN Address	80	*	*		Anti-Logout Rule	
☐	✗ 0/0 B	IPv4 TCP	LAN subnets	*	192.168.30.101	80 (HTTP)	*	none		Blocca accesso DVWA	
☐	✓ 3/2.29 MIB	IPv4 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	
☐	✓ 0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN IPv6 to any rule	

Add Add Delete Toggle Copy Save Separate

```
kali@kali:~$ ping 192.168.30.101
PING 192.168.30.101 (192.168.30.101) 56(84) bytes of data:
64 bytes from 192.168.30.101: icmp_seq=1 ttl=63 time=2.88 ms
64 bytes from 192.168.30.101: icmp_seq=2 ttl=63 time=1.67 ms
64 bytes from 192.168.30.101: icmp_seq=3 ttl=63 time=7.01 ms
64 bytes from 192.168.30.101: icmp_seq=4 ttl=63 time=5.82 ms
64 bytes from 192.168.30.101: icmp_seq=5 ttl=63 time=4.81 ms
64 bytes from 192.168.30.101: icmp_seq=6 ttl=63 time=4.23 ms
64 bytes from 192.168.30.101: icmp_seq=7 ttl=63 time=3.60 ms
^C
--- 192.168.30.101 ping statistics ---
7 packets transmitted, 7 received, 0% packet loss, time 601ms
rtt min/avg/max/mdev = 2.884/4.573/7.008/1.324 ms

kali@kali:~$ ping 192.168.30.101
PING 192.168.30.101 (192.168.30.101) 56(84) bytes of data:
64 bytes from 192.168.30.101: icmp_seq=1 ttl=63 time=2.72 ms
64 bytes from 192.168.30.101: icmp_seq=2 ttl=63 time=3.62 ms
64 bytes from 192.168.30.101: icmp_seq=3 ttl=63 time=5.67 ms
64 bytes from 192.168.30.101: icmp_seq=4 ttl=63 time=1.32 ms
64 bytes from 192.168.30.101: icmp_seq=5 ttl=63 time=5.13 ms
64 bytes from 192.168.30.101: icmp_seq=6 ttl=63 time=3.92 ms
64 bytes from 192.168.30.101: icmp_seq=7 ttl=63 time=4.38 ms
^C
--- 192.168.30.101 ping statistics ---
7 packets transmitted, 7 received, 0% packet loss, time 601ms
rtt min/avg/max/mdev = 2.722/4.110/5.672/0.954 ms
```

pfSense.localdomain - Firefox

Not Secure http://192.168.10.11/interfaces.php?if=lan

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

pfSense COMMUNITY EDITION

System Interfaces Firewall Services VPN Status Diagnostics Help

Screenshot taken

View image

Interfaces / LAN (le1)

General Configuration

Enable	☒ Enable interface
Description	LAN Enter a description (name) for the interface here.
IPv4 Configuration Type	Static IPv4
IPv6 Configuration Type	None
MAC Address	xxxxxxxxxxxx This field can be used to modify ("spoof") the MAC address of this interface. Enter a MAC address in the following format: xxxxxxxx:xxxx:xxxx or leave blank.
MTU	1500 If this field is blank, the adapter's default MTU will be used. This is typically 1500 bytes but can vary in some circumstances.
MSS	1460 If a value is entered in this field, then MSS clamping for TCP connections to the value entered above minus 40 for IPv4 (TCP/IPv4 header size) and minus 60 for IPv6 (TCP/IPv6 header size) will be in effect.
Speed and Duplex	Default (no preference, transmit and receive)